

Cloud Security Model & IAM

The Shared Responsibility Model

Cloud = a RENTAL. Both parties have duties:

IaaS:	You: OS, apps, data, network config	Cloud: physical, hypervisor
PaaS:	You: apps, data, config	Cloud: runtime, host, patch
SaaS:	You: data, users, settings	Cloud: everything else (mostly)

The **eternal misconfiguration**: teams assumed the cloud provider "secures it" – and left buckets public, databases open, keys in code. Always ask: **who owns THIS layer?**

The Cloud Attack Surface (the Shell of Cloud Breaches)

Misconfigured storage (public S3/GCS bucket = data exfiltration)

Credential leakage (API keys in code/GitHub – M10's GitHub recon)

IAM over-privilege (wide roles = an account jacked = whole org plunder)

SSRF hitting metadata (cloud metadata = the keys to the kingdom, M11)

Shadow assets (new regions/zones are forgotten, unprotected)

IAM: The Real Boundary

Traditional network edge (your firewall) is gone. The new perimeter is **identity**:

Least privilege – every role/policy grants the minimum

MFA everywhere – on roots, admins, console

Short-lived credentials instead of static keys (tokens, not secrets)

Immutable roles (arn:aws:iam::...:role/read-only-orders) used by apps, not long-lived passwords

Audit trails – who called what, when (CloudTrail / equivalent)

```
{ "Effect": "Allow", "Action": "s3:GetObject",  
  "Resource": "arn:aws:s3:::production-orders/*" }
```

Infra as Code & Security as Code

Cloud config written as code (Terraform / CloudFormation) means config is **reviewable, write-protected, and testable**:

pre-commit scanning for public buckets, wide IAM

`checkov` / `tfsec` on CI runs seconds after commit

The Cloud Catastrophe Checklist (blue team)

Default regions – who else can create in MY tenant?

Root account – is MFA bound and is it used only for emergencies?

Service keys – in secret store with rotation, or in a git history?

Public exposure – one query finds all buckets/DBS that are public

The 2020s lesson: cloud isn't 'more vulnerable' – it's *differently* vulnerable, concentrated in IAM + exposure + shadow. Master IAM and you master cloud.

[← Module start](#)

[DevSecOps: Securing the CI/CD ...](#)